

Manual 43 — Implementação Controlada de Segurança e Privacidade em Nuvem ISO/IEC 27017 e 27018

****Linha de base:**** ISO/IEC 27017:2026 Edição 2 e ISO/IEC 27018:2025 Edição 3. ****Limite de copyright:**** orientação original do projeto; não reproduz texto protegido e não é tradução autorizada da ISO.

Chapter 01 — Fontes e limite de copyright

Mantenha edições, acesso autorizado, resumos próprios, restrições, citações e reverificação antes da liberação.

Chapter 02 — Escopo e relações entre normas

Delimite 27017, 27018 e relações com 27001, 27002, 27701, contratos e legislação.

Chapter 03 — Modelos de serviço em nuvem

Classifique IaaS, PaaS, SaaS e serviços gerenciados; atribua responsabilidades por modelo.

Chapter 04 — Responsabilidade cliente-provedor

Defina proprietários de segurança, privacidade, arquitetura, incidentes, fornecedores e evidências.

Chapter 05 — Responsabilidade compartilhada

Mantenha matrizes por serviço com propriedade, configuração, evidências, dependências e exceções.

Chapter 06 — Governança de segurança da informação

Integre riscos de nuvem a políticas, avaliação, tratamento, mudanças, garantia e análise crítica.

Chapter 07 — Ativos e configuração

Inventarie contas, cargas, dados, imagens, segredos, regiões, dependências e configurações aprovadas.

Chapter 08 — Identidade e acesso

Governe federação, ciclo de contas, autenticação, autorização, identidades de serviço e revisões.

Chapter 09 — Administração privilegiada

Aplique menor privilégio, MFA, elevação temporária, registros, contas emergenciais e segregação.

Chapter 10 — Ambientes virtualizados e compartilhados

Avalie isolamento, multitenancy, contêineres, hipervisores, serviços compartilhados e evidências do provedor.

Chapter 11 — Operações administrativas

Controle manutenção, suporte, automação, consoles, mudanças emergenciais e acesso remoto.

Chapter 12 — Arquitetura de rede e nuvem

Projete segmentação, entrada/saída, conectividade privada, endpoints, DNS, firewalls e revisão de exposição.

Chapter 13 — Registro e monitoramento

Defina logs, telemetria, alertas, retenção, sincronização, integridade, centralização e investigação.

Chapter 14 — Criptografia e chaves

Defina criptografia, propriedade de chaves, rotação, backup, HSM, segredos, revogação e evidências.

Chapter 15 — Vulnerabilidades e configuração

Gerencie imagens, hosts, contêineres, dependências, patches, postura, SLAs e exceções.

Chapter 16 — Gestão de incidentes

Defina detecção, triagem, evidências, comunicações, contenção, privacidade, notificação e lições aprendidas.

Chapter 17 — Resiliência e disponibilidade

Estabeleça objetivos, zonas/regiões, backups, recuperação, capacidade, continuidade e testes.

Chapter 18 — Portabilidade e interoperabilidade

Planeje formatos, interfaces, migração, extração, dependências, lock-in, testes e saída.

Chapter 19 — Exclusão e devolução segura

Controle devolução, eliminação, apagamento criptográfico, cópias residuais, backups e evidências do provedor.

Chapter 20 — Fornecedores e suboperadores

Inventarie terceiros, contratos, localizações, mudanças, incidentes, auditoria, remediação e término.

Chapter 21 — Escopo de operador de PII em nuvem pública

Determine papéis e documento instruções, categorias, finalidades e camadas jurídicas sem transformar ISO em lei.

Chapter 22 — Instruções do cliente e limites de finalidade

Documente processamento autorizado, usos proibidos, mudanças, suporte, retenção e eliminação.

Chapter 23 — Divulgação e transparência

Mantenha informações sobre provedor, suboperadores, localizações, capacidades, mudanças e riscos materiais.

Chapter 24 — Suporte a violações

Defina detecção, comunicação, evidências, apoio à avaliação/notificação, coordenação e remediação.

Chapter 25 — Localização e transferências de dados

Rastreie armazenamento, replicação, suporte, acesso remoto, transferências e decisões jurisdicionais.

Chapter 26 — Controles contratuais

Traduza responsabilidades em contratos, DPA, SLA, incidentes, auditoria, suboperadores, exclusão e saída.

Chapter 27 — Evidências e auditabilidade

Defina evidências de responsabilidades, configurações, acesso, logs, incidentes, eliminação, resiliência e privacidade.

Chapter 28 — Tratamento de riscos

Avalie ameaças de nuvem, falhas compartilhadas, concentração, exposição, resiliência e limitações de saída.

Chapter 29 — Crosswalks 27001, 27002 e 27701

Use crosswalks próprios com premissas, não equivalência, diferenças de edição e mapeamentos de evidências.

Chapter 30 — Métricas e limites de garantia

Meça postura, privilégios, incidentes, fornecedores, recuperação, eliminação, exceções e cobertura.

Chapter 31 — Localização, proveniência e copyright

Congele EN/es-419/pt-BR, preserve aviso de tradução não autorizada e vincule candidatos a SHA-256.

Chapter 32 — Reverificação de edição e liberação

Revalide versões ISO, dependências, predecessor 42, identidade exata, QA limpa e registros antes de publicar.